

National Forensic Sciences University, Gandhinagar

School of Cyber Security and Digital Forensics



**National Forensic
Sciences University**

Knowledge | Wisdom | Fulfilment

An Institution of National Importance
(Ministry of Home Affairs, Government of India)

Assignment 1

Subject Code : CTMSCS S1 P2

Subject Name: Cyber Security Audit & Compliance

Submitted To : Dharmesh Dave

Submitted By:

Aastha Thakker (25MSCCS004)

Rahul Bothra (25MSCCS008)

Jiya Joshi (25MSCCS016)

Bhavya Negi (25MSCCS048)

Aditya Dey (25MSCCS056)

Submission Date: 30th November, 2025

Table of Contents

Sr. No.	Section Title
1	Introduction
2	Scope of HIPAA
3	Purpose of HIPAA
4	Applicability
5	HIPAA Safeguards (Administrative, Physical, Technical)
6	Organizational Requirements
7	Policies, Procedures, and Documentation
8	References

1. Introduction

The Health Insurance Portability and Accountability Act of 1996 (HIPAA) is the cornerstone of healthcare legislation in the United States. Signed into law by President Bill Clinton on August 21, 1996, HIPAA (Public Law 104-191) was originally introduced to improve the portability of health insurance coverage for American workers. However, it has since evolved into the primary federal statute governing the privacy, security, and integrity of medical data.

In the modern digital era, where healthcare records are increasingly electronic, HIPAA serves as the regulatory framework that mandates how Protected Health Information (PHI) is collected, stored, shared, and defended against breaches.

HIPAA ensures that:

- Patients have **control over their medical data**
- Healthcare providers maintain **strict confidentiality**
- Organizations use **secure technological and administrative measures** to protect electronic health records (ePHI)
- Data breaches are **reported responsibly**
- Violators face **legal and financial penalties**

HIPAA is the backbone of **healthcare data protection**, making sure sensitive medical information remains private, accurate, and secure. It is one of the most important laws for any organization working with patient data or healthcare technology.

The Standards for Privacy of Individually Identifiable Health Information (“Privacy Rule”) establishes, for the first time, a set of national standards for the protection of certain health information. The U.S. Department of Health and Human Services (“HHS”) issued the Privacy Rule to implement the requirement of the Health Insurance Portability and Accountability Act of 1996 (“HIPAA”).

HIPAA, enacted in the United States in 1996, is a federal law designed to protect individuals’ medical records and other personal health information (PHI). Its key objectives include:

- **Portability of Health Insurance:** Ensures individuals maintain health insurance coverage when changing jobs.
- **Accountability and Privacy:** Protects sensitive personal health information from unauthorized access or disclosure.
- **Administrative Simplification:** Reduces healthcare fraud, streamlines claims processing, and standardizes electronic health transactions.

HIPAA is a U.S. law created to protect the privacy and security of patient health information. It establishes clear rules for how hospitals, insurance companies, and healthcare technology

providers must store, share, and safeguard medical data. HIPAA includes the Privacy Rule, Security Rule, Breach Notification Rule, and Enforcement Rule.

It mandates safeguards like encryption, access controls, staff training, and physical security, with strict penalties for violations. Overall, HIPAA builds trust and ensures accountability within the healthcare data ecosystem.

HIPAA establishes national standards to ensure that sensitive medical data is handled properly as healthcare organizations transitioned from paper-based systems to digital health records. This law ensures that patient information is not misused, accessed without permission, or exposed during data breaches.

2. Scope

2.1 Regulatory Scope of HIPAA

HIPAA consists of four regulatory components: (a) Privacy Rule governing permissible uses and disclosures of PHI, (b) Security Rule defining safeguards for ePHI, (c) Breach Notification Rule mandating reporting of unauthorized disclosures, and (d) Enforcement Rule specifying penalties and compliance processes.

2.2 Information Scope

HIPAA applies to any individually identifiable health information in any form. This includes electronic PHI stored or transmitted through digital systems, verbal PHI exchanged during clinical interactions, and paper-based PHI contained in physical medical records. Any data linked to an individual's diagnosis, treatment, or payment activities falls within scope.

2.3. Operational Scope

HIPAA covers all activities associated with the handling of PHI. This includes data creation, processing, storage, and transmission; administrative operations such as billing and claims management; and clinical functions including diagnosis, treatment, and care coordination. Information sharing with authorized internal or external parties also falls under its operational scope.

2.4 Organizational Scope

HIPAA applies to healthcare providers, health plans, and entities involved in processing or transmitting health information. It also extends to business associates and subcontractors operating under contractual obligations, as well as hybrid entities where only specific departments handle PHI. All authorized workforce members, employees, trainees, and volunteers are included.

2.5 System and Infrastructure Scope

HIPAA governs all technical environments used to store or transmit PHI. This includes on-premise systems, cloud-based platforms operating under compliant agreements, medical devices and IoT components integrated into care delivery, workstations and mobile devices used for clinical tasks, and backup or disaster recovery systems supporting data availability.

2.6 Compliance Scope

HIPAA compliance requires implementation of written policies and procedures, workforce training, periodic risk assessments, and continuous monitoring of safeguards. It also includes PHI lifecycle management covering retention, storage, and disposal and the establishment of incident response and corrective action processes.

2.7 Geographic Scope

HIPAA applies to PHI belonging to individuals in the United States, regardless of where the information is processed or stored. Any entity located outside the U.S. must comply if it handles PHI originating from U.S. healthcare services.

2.8 Exclusions from HIPAA Scope

HIPAA does not apply to de-identified datasets that meet regulatory anonymization standards, research datasets stripped of identifiers, employee records maintained for non-medical purposes, personal notes kept solely for individual use, or health information shared voluntarily in non-clinical environments.

3. Purpose

The Health Insurance Portability and Accountability Act (HIPAA) is to protect patient privacy, secure health information, streamline healthcare transactions, reduce fraud, ensure health insurance portability, and set national standards for healthcare identifiers.

The primary purpose of HIPAA is to establish national standards for the protection and privacy of Protected Health Information (PHI) in order to ensure the confidentiality, integrity, and availability of PHI. HIPAA also sets forth rules regarding how PHI can be used or disclosed and provides individuals access to their records.

PHI (Protected Health Information) refers to **any health-related information** that can be used to **identify an individual**. For example : Medical history , Fingerprints, voice prints , Lab reports etc.

5 Key Purposes of HIPAA:



Protecting the Privacy of Patient Information

1. Protecting the Privacy of Patient Information

One of the critical purposes of HIPAA is to protect patient privacy. It does this by setting standards for the protection and privacy of Protected Health Information (PHI). This ensures that healthcare providers, insurers, and other entities involved with handling PHI take appropriate measures for its security



Promoting the Security of Patient Information

2. Promoting the Security of Patient Information

HIPAA's fundamental purpose of promoting the security of patient information is critical for protecting individuals' rights regarding their medical records. The standard requires healthcare providers, insurers, and other entities handling PHI to take appropriate measures for its security.

This includes implementing technical safeguards such as encryption and access control systems, administrative safeguards such as policies and procedures about data management, and physical safeguards like restricted access to servers or storage media containing sensitive data.



Standardizing the Exchange of Health Information

3. Standardizing the Exchange of Health Information

Regardless of where data is processed, healthcare organizations must guarantee the accuracy, and consistency by standardizing the transmission of health information. Healthcare providers in the past stored and exchanged patient health information using several systems, which caused discrepancies and inefficiencies in the process.

HIPAA addresses this by establishing standards for the format and content of electronic health records, simplifying the electronic information transmission between healthcare providers.



Encouraging Electronic Transactions

4. Encouraging Electronic Transactions

HIPAA encourages electronic transactions by setting standards for the use and disclosure of protected health information (PHI). It requires healthcare providers, insurers, and other entities handling PHI to take appropriate measures for its security.

HIPAA also promotes interoperability between different healthcare systems through standardized code sets and electronic transactions used in healthcare processes like billing; this helps ensure that only those who need access to PHI have it while protecting individuals' rights over their medical records.



Improving public trust in the Healthcare System

5. Promoting Public Trust in the Healthcare System

Under the HIPAA Privacy Rule, individuals have a right to access and inspect their medical records to ensure the accuracy of their information. The Privacy Rule requires that covered entities provide individuals with access to their health information, including medical records and billing statements. The purpose of HIPAA plays an important role when an individual requests a copy of the health information kept by the covered entity.

HIPAA empowers patients to view and obtain copies of their health information as they please and allows them to request corrections if they find any inaccuracies or omissions in their data.

4. Applicability

HIPAA does not include all types of health-related information. It only applies when organizations that are subject to the Act's regulatory purview to create, receive, maintain, or transfer identifiable health information.

For HIPAA to apply, three elements must be present simultaneously:

- The information identifies an individual (directly or indirectly).
- The information relates to the individual's physical or mental health, healthcare provision, or payment for healthcare.
- The information is created, used, or disclosed by an entity governed by HIPAA.

If any of these conditions are absent, HIPAA is not triggered.

4.1 Covered Entities

HIPAA directly regulates covered entities. There are three primary types of covered entities:

A. Healthcare Providers

This includes doctors, clinics, dentists, psychologists, hospitals, pharmacies, and other medical practitioners who electronically transmit health information related to certain transactions. If you deliver care and bill for it electronically, you fall into this category.

B. Health Plans

Organizations that provide or pay the cost of medical care. These includes:

- Health Insurance Companies
- Employer-sponsored health plans
- Medi-Care and Aid
- Long-term care insurers (except policies offering solely fixed indemnity benefits)

C. Healthcare Clearinghouses

organizations that convert nonstandard health data into standard forms or the other way around. Clearinghouses handle medical data on behalf of third parties rather than directly providing healthcare.

Business Associates

A business partner is any person or organization other than a member of a covered entity's workforce that performs responsibilities or operations on its behalf that include the use or disclosure of protected health information (PHI). Examples include:

- Billing and coding services
- Data storage or cloud hosting providers
- IT management companies
- Legal and accounting firms handling PHI
- Data analytics and machine learning vendors using PHI

4.2 Exceptions

HIPAA does not regulate every type of health-related information. It is not applicable to:

- Consumer health applications and wearable device data (e.g., fitness tracking applications)
- Personal health journals maintained privately by individuals
- Life insurance providers
- Workers' compensation claim management
- Disability insurance providers
- Student health records maintained by schools (regulated under FERPA)
- Employers handling employee medical documentation for administrative purposes
- Law enforcement agencies handling medical information for investigative activities
- Public online postings by individuals of their own medical information

The presence of health-related data alone does not impose HIPAA obligations.

4.3 Applicability to Individuals

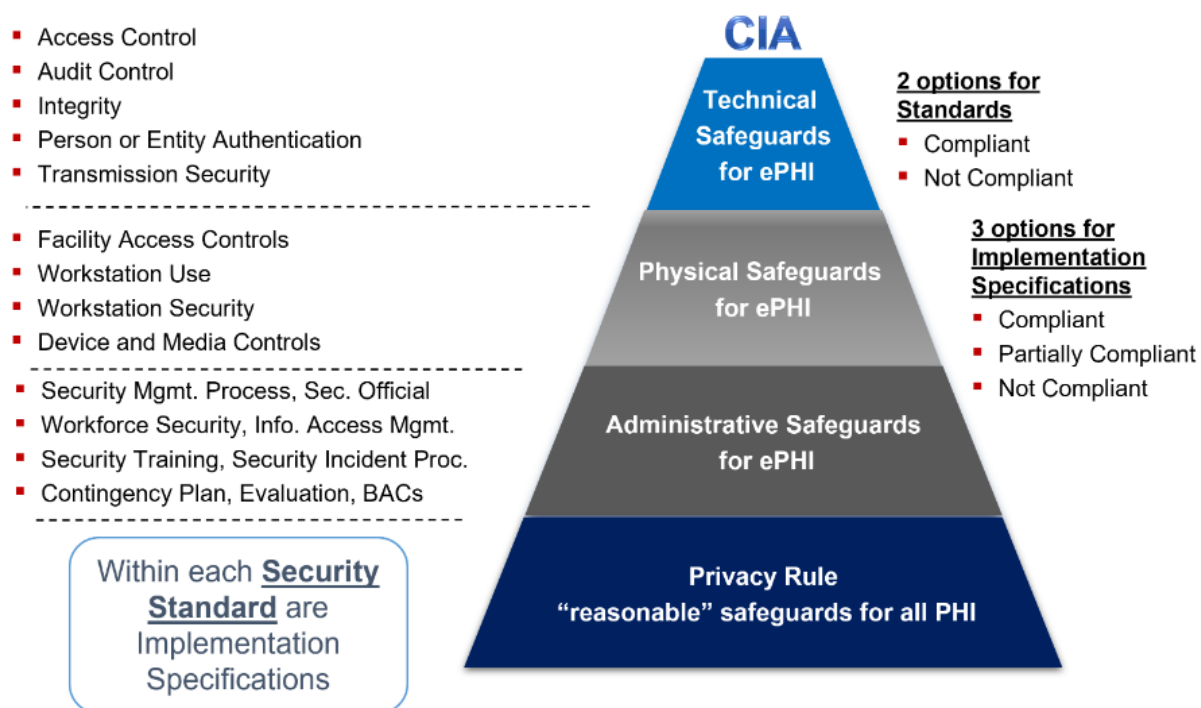
Individuals are not restricted by HIPAA rules when disclosing their personal health information. HIPAA applies to organizations rather than individual citizens discussing or sharing their personal health information

5. HIPAA Controls (Safeguards):

Measurable mechanisms, such as policies, standards, configurations, system settings, and operational procedures, implemented to ensure that an organization's processes operate as intended. Controls are assessed to verify whether they mitigate identified risks, preserve data integrity, ensure confidentiality/availability, and maintain regulatory compliance.

The Health Insurance Portability and Accountability Act (HIPAA) establish national standards for protecting health information in the United States. Its controls, formally defined as safeguards, are outlined primarily under the HIPAA Security Rule (45 CFR Part 164, Subpart C). These safeguards apply to all covered entities and business associates that create, receive, maintain, or transmit electronic protected health information (ePHI).

The purpose of these controls is to ensure the **confidentiality, integrity, and availability** of healthcare data. These controls are categorized into **Administrative, Physical, and Technical Safeguards**.



A) Administrative Controls:

Administrative safeguards define the governance and procedural controls required to protect electronic protected health information (ePHI). A covered entity or business associate must implement these measures in accordance with §164.306.

A.1 Security Management Process

- **Risk Analysis (Required):** Conduct a thorough assessment of risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI.
- **Risk Management (Required):** Implement security measures that reduce identified risks to an appropriate level.
- **Sanction Policy (Required):** Apply disciplinary actions to workforce members who violate security policies.
- **Information System Activity Review (Required):** Regularly review audit logs, access reports, and incident tracking reports.

A.2 Assigned Security Responsibility

- Designate a Security Official responsible for developing, implementing, and managing required security policies and procedures.

A.3 Workforce Security

- **Authorization/Supervision (Addressable):** Define procedures for supervising workforce members who handle or may access ePHI.
- **Workforce Clearance (Addressable):** Ensure access assignments align with a worker's role and responsibilities.
- **Termination Procedures (Addressable):** Revoke access rights promptly when employment or role relationships end.

A.4 Information Access Management

- **Isolating Clearinghouse Functions (Required):** Prevent unauthorized internal access to clearinghouse ePHI when part of a larger organization.
- **Access Authorization (Addressable):** Define mechanisms for granting access to systems or processes containing ePHI.
- **Access Establishment/Modification (Addressable):** Document, review, and adjust user access rights based on policy requirements.

A.5 Security Awareness and Training

- **Security Reminders (Addressable):** Provide periodic updates.
- **Protection from Malicious Software (Addressable):** Implement procedures to detect, prevent, and report malware.
- **Log-in Monitoring (Addressable):** Monitor login attempts and flag discrepancies.

- **Password Management (Addressable):** Define secure password creation, change, and protection procedures.

A.6 Security Incident Procedures

- **Response and Reporting (Required):** Identify, respond to, mitigate, and document security incidents involving ePHI.

A.7 Contingency Plan

- **Data Backup Plan (Required):** Maintain retrievable copies of ePHI.
- **Disaster Recovery Plan (Required):** Restore data following loss or damage.
- **Emergency Mode Operation Plan (Required):** Ensure continuation of critical processes during emergencies.
- **Testing and Revision (Addressable):** Periodically test and update contingency plans.
- **Applications and Data Criticality Analysis (Addressable):** Prioritize systems and data to support recovery planning.

A.8 Evaluation

- Conduct periodic technical and non-technical evaluations to verify security controls remain effective, especially after environmental or operational changes.

A.9 Business Associate Contracts

- Covered entities must obtain **written assurances** (as per §164.314(a)) that business associates safeguard ePHI appropriately.
- Business associates must likewise ensure subcontractors provide equivalent protections.
- All assurances must be documented through formal contracts or agreements.

B) Physical Controls

Physical safeguards address the facility-level and device-level protections required to secure electronic protected health information (ePHI). A covered entity or business associate must implement these measures in accordance with §164.306.

B.1 Facility Access Controls

Implement policies and procedures to restrict physical access to facilities and electronic information systems, while permitting authorized access.

Implementation Specifications

- **Contingency Operations (Addressable):** Establish procedures allowing facility access during emergencies to support data restoration and emergency mode operations.
- **Facility Security Plan (Addressable):** Implement policies that safeguard facilities and equipment against unauthorized physical access, tampering, and theft.
- **Access Control and Validation Procedures (Addressable):** Define access validation methods based on roles, including visitor management and controlled access to environments used for system testing or revision.
- **Maintenance Records (Addressable):** Document repairs and modifications to facility components relevant to security (e.g., hardware, locks, walls, and doors).

B.2 Workstation Use

Implement policies that define the appropriate use, operational procedures, and physical conditions for workstations accessing ePHI. These policies must specify the permissible functions and expected secure practices associated with each workstation type.

B.3 Workstation Security

Deploy physical safeguards to restrict workstation access exclusively to authorized personnel. This includes securing workstation placement, physical barriers, and access controls to prevent unauthorized viewing or use.

B.4 Device and Media Controls

Develop and implement policies governing the receipt, transfer, movement, and disposal of hardware and electronic media containing ePHI.

Implementation Specifications

- **Disposal (Required):** Establish secure disposal procedures for ePHI and the media or hardware storing it.
- **Media Re-use (Required):** Clear or sanitize ePHI from electronic media prior to reuse, following approved data sanitization methods.
- **Accountability (Addressable):** Maintain logs that track the movement of hardware and media, and assign responsibility for such items.
- **Data Backup and Storage (Addressable):** Create a retrievable exact copy of ePHI before transferring equipment.

C) Technical Safeguards

Technical safeguards define the technological controls and system-level mechanisms required to protect electronic protected health information (ePHI). A covered entity or business associate must

implement these controls in accordance with §164.306 to ensure secure access, transmission, integrity, and authentication of ePHI.

C.1 Access Control

Implement technical policies and procedures to ensure that only authorized persons or software programs can access ePHI.

Implementation Specifications

- **Unique User Identification (Required):** Assign a unique user ID or identifier to each user for tracking and accountability.
- **Emergency Access Procedures (Required):** Establish procedures to access necessary ePHI during emergencies.
- **Automatic Logoff (Addressable):** Enforce session termination after a defined period of inactivity.
- **Encryption and Decryption (Addressable):** Implement mechanisms for encrypting and decrypting ePHI where appropriate.

C.2 Audit Controls

Implement hardware, software, and/or procedural mechanisms that record, monitor, and examine system activity involving ePHI. These controls support incident detection, analysis, and forensic review.

C.3 Integrity Controls

Implement policies and technical mechanisms to protect ePHI from improper alteration or destruction.

Implementation Specification

- **Mechanism to Authenticate ePHI (Addressable):** Use electronic methods, such as checksums, hashing, or digital signatures, to verify that ePHI has not been altered or destroyed in an unauthorized manner.

C.4 Person or Entity Authentication

Implement procedures to verify that any person or system seeking access to ePHI **is accurately identified and authenticated**. Examples include passwords, multi-factor authentication, digital certificates, or biometric verification.

C.5 Transmission Security

Implement technical measures to safeguard ePHI transmitted over electronic communications networks.

Implementation Specifications

- **Integrity Controls (Addressable):** Ensure that transmitted ePHI is not improperly modified without detection until disposal.
- **Encryption (Addressable):** Implement encryption mechanisms for ePHI transmission when appropriate to prevent unauthorized interception or access.

6. Organizational Requirements

Organizational safeguards govern contracts and inter-entity obligations when handling ePHI.

6.1 Business Associate Contracts

Business Associate Agreements (BAAs) (Required): Contracts must ensure the business associate:

- Complies with all applicable HIPAA security standards;
- Requires subcontractors to implement equivalent safeguards;
- Reports any security incident or breach to the covered entity.

Requirements apply similarly to subcontractor agreements.

6.2 Group Health Plan Requirements

Unless exceptions apply, group health plans must ensure plan documents require the plan sponsor to:

- Implement administrative, physical, and technical safeguards for ePHI.
- Maintain adequate separation between plan operations and sponsor operations.
- Ensure agents handling ePHI implement equivalent safeguards.
- Report security incidents to the group health plan.

7. Policies, Procedures, and Documentation

7.1 Policies and Procedures

Covered entities and business associates must implement reasonable and appropriate policies and procedures to comply with all Security Rule standards and implementation specifications. Policies may be revised at any time, provided the updates are documented and implemented in compliance with the Rule.

7.2 Documentation

Entities must maintain written (including electronic) documentation of all required policies, procedures, assessments, and actions.

Implementation Specifications

- **Time Limit (Required):** Retain documentation for **at least 6 years** from its creation or last effective date.
- **Availability (Required):** Ensure documentation is accessible to personnel responsible for implementing its procedures.
- **Updates (Required):** Review and update documentation periodically to reflect environmental or operational changes affecting ePHI security.

References

1. HIPAA Journal. (n.d.). *Covered entities under HIPAA*. <https://www.hipaajournal.com/covered-entities-under-hipaa/>
2. Sprinto. (2023). *Purpose of HIPAA*. <https://sprinto.com/blog/what-is-the-purpose-of-hipaa/>
3. NIST. (n.d.). *HIPAA security guidance*. <https://www.nist.gov/itl/applied-cybersecurity/hipaa>
4. HIPAA Academy. (2023). *HIPAA Security Rule*. <https://hipaaacademy.net/hipaa-security-rule/>
5. U.S. Department of Health & Human Services. (n.d.). *HIPAA Security Rule*. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
6. AMA. (2023). *HIPAA compliance overview*. <https://www.ama-assn.org/practice-management/hipaa>